KIPUCON 2026 · LIMA, PERU · MAY 13

When Elevators Get Hacked

One packet. No authentication. Passengers trapped.

Sec-Llama | OT Cyber Security

"Decrypting the Future. Honoring the Past."

IT Steals Data. OT Breaks Things.

IT — Information Technology

Your phone, email, banking app, company servers.

When IT gets hacked:

Hackers steal your data — passwords, credit cards, personal information.
Serious? Yes. Immediately life-threatening? Usually not.

Examples:

Data breaches · Ransomware on company PCs
Phishing attacks · Stolen credit cards

Built: In the internet era. Security was part of the design.

≠

OT — Operational Technology

Elevators, power grids, water treatment, factory machines.

When OT gets hacked:

Physical things stop working — or do the wrong thing.
Blackouts, explosions, trapped people, equipment destroyed.

Examples:

Power grid shutdown · Water plant tampering
Factory sabotage · Elevator lockdowns

Built: Decades ago. Security was never part of the design.

LIVE CASE · FEBRUARY 2026 · BARCELONA, SPAIN

A Weekend Project That Went Wrong.

01 He bought a $2,000 robot vacuum — the DJI Romo.

↓

02 He had a fun idea: control it with his PlayStation 5 controller.

↓

03 He used an AI tool to understand how the vacuum talks to the internet.

04 THE MOMENT EVERYTHING CHANGED

When his app connected to DJI's servers...
...6,700 other vacuums in 24 countries started reporting to him.

He wasn't hacking. DJI's server just handed him everything. No questions asked.

WHAT HE COULD ACCESS — WITHOUT ANY PERMISSION:

📷	**Live camera feed**	from inside 6,700 strangers' homes
🎙️	**Live microphone audio**	everything said in those rooms
🗺️	**Detailed floor plans**	layout of every home the vacuum mapped
📍	**Exact location**	GPS coordinates via IP address

From Living Room to Control Room.

DJI Romo — Consumer device

Camera feed	Live video of strangers' living rooms
Microphone	Audio from inside private homes
Floor map	2D home layout — 24 countries
Location	GPS coords via IP address
Control	Start / stop / redirect the vacuum

→

OT / ICS — Industrial control system

Camera feed	Live view of production floor / mine site
Sensor data	Pressure, temperature, gas — live readings
Plant map	Full layout of refinery or substation
Location	Physical site of critical infrastructure
Control	Actuators, valves, PLCs — real consequences

ROOT CAUSE No guest list on the server — one valid device key gave access to every device on the network. In a vacuum: surveillance. In an industrial system: physical control.

Source: The Verge / Sammy Azdoufal · February 2026

10 Floors. 3 Elevators. 1 Vulnerability.

01 SCADA

The Brain

Decides which elevator goes where.
Checks status 10 times per second.

In plain English:

Think of it as air traffic control — but for elevators.

02 3 PLCs

The Controllers

One mini-computer per elevator.
Executes the commands it receives.

In plain English:

Think of it as the pilot who follows the control tower's orders.

03 Modbus/TCP

The Language

The protocol machines use to talk.
Designed in 1979. No passwords.

In plain English:

Think of it as a walkie-talkie with no lock — anyone can transmit.

⚠ THE VULNERABILITY

The PLC's fault register is open to anyone on the network — no login, no password, no check.

Four Steps. No Lock to Pick.

01 SEE

Reconnaissance

"We look around"

We connect to the building's control network — no password required.
We can see all three elevators: which floor they're on, how full the command queue is, their current status.

Technical detail:

FC=3 · Read all Modbus registers · No credentials required

02 OVERWHELM

Command Flood

"We clog the inbox"

We send 24 fake floor requests per second to one elevator.
The queue fills up. Every legitimate call from the building system gets rejected.

Technical detail:

FC=15 · Write Multiple · Queue overflow

03 STRIKE

Fault Injection

"One command. Done."

We send a single command: set the fault register to 'critical failure'.
The elevator stops instantly. Doors lock. Passengers are trapped.

Technical detail:

FC=6 · Write Register · HR4 = 0x10

04 STAY

Persistence

"We keep it locked"

We re-send that same command every 2 seconds.
The elevator cannot auto-recover. It stays locked as long as we want.

Technical detail:

FC=6 · Every 2 seconds · Prevents TTL recovery

DEMO

Elevator Hacking in Action

Terminal 1 — start the server:

```
python elevator_server.py
```

Terminal 2 — launch the attack:

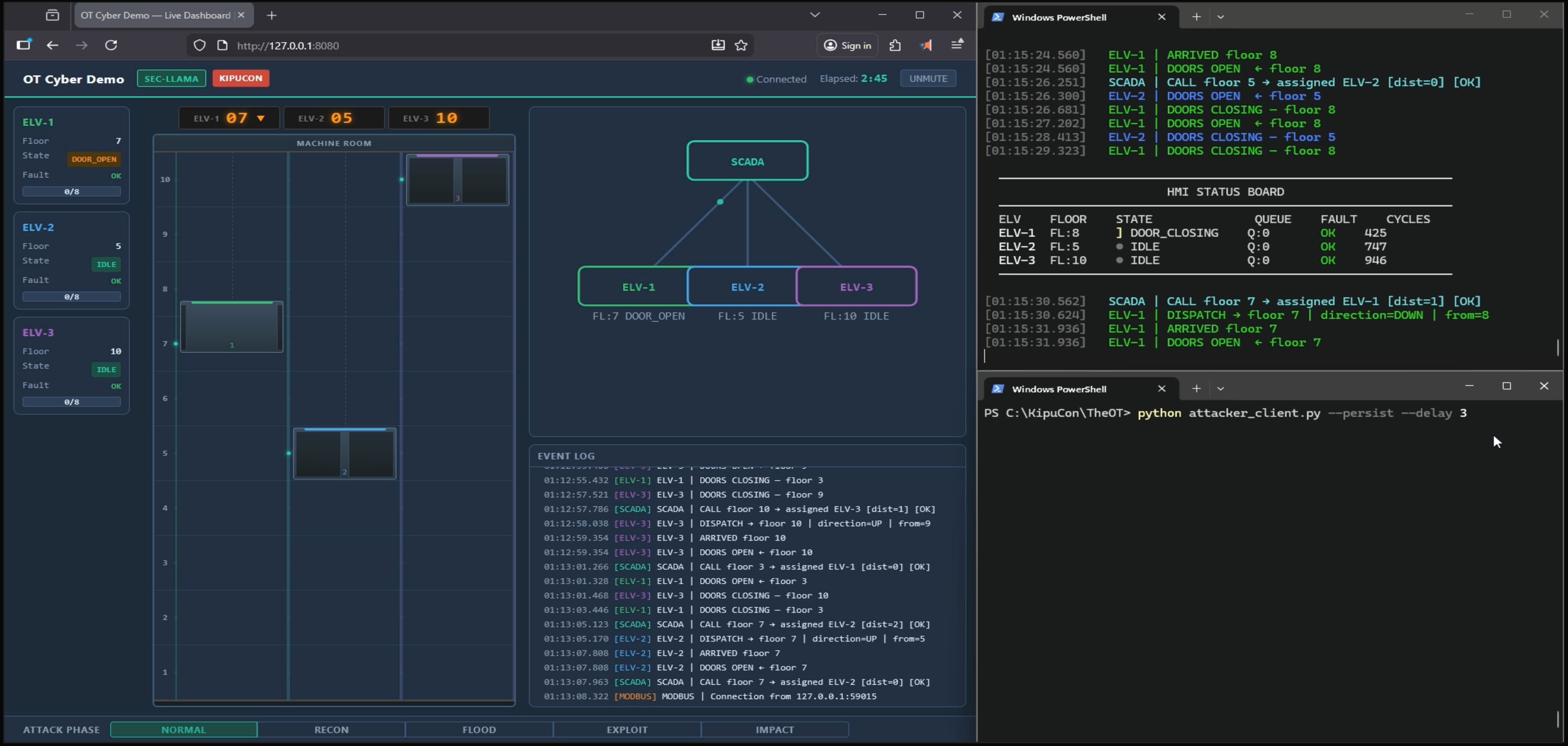
```
python attacker_client.py --persist --delay 3
```

Dashboard: http://localhost:8080

THE INFRASTRUCTURE

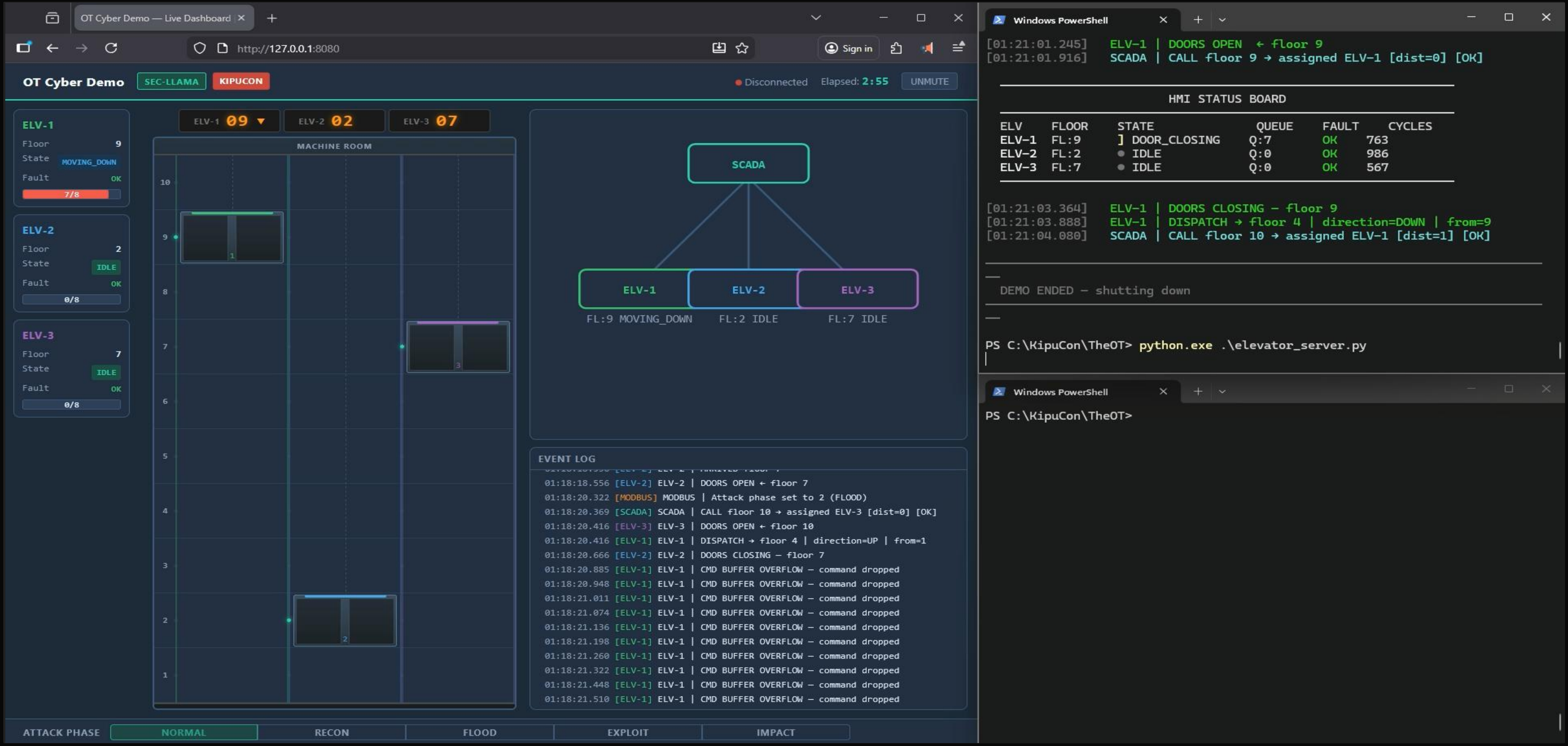
PHASE 01

Demo Terminals & Dashboard Overview



PHASE 02

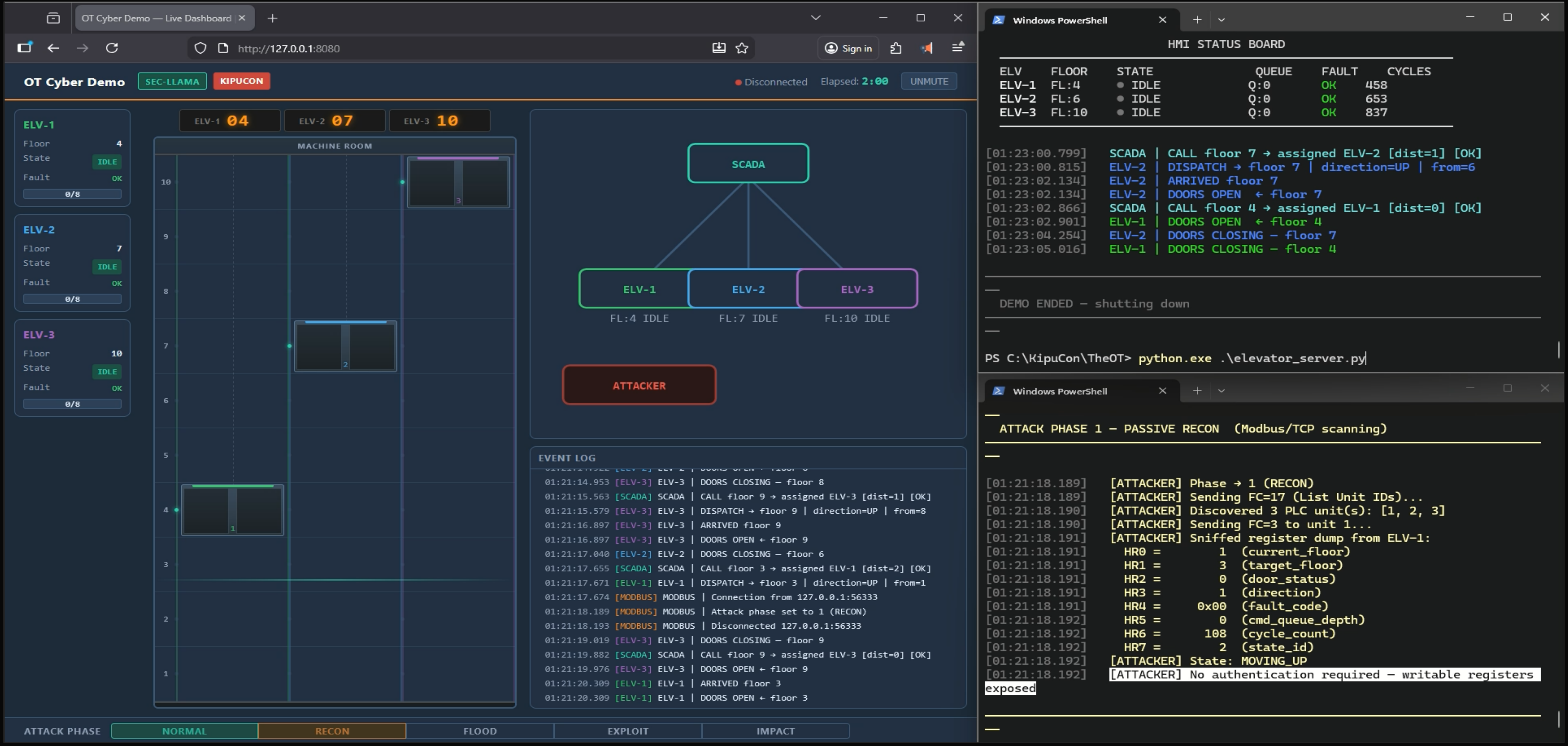
Network Reconnaissance & Target Discovery



ATTACK PHASE — FLOOD

PHASE 02

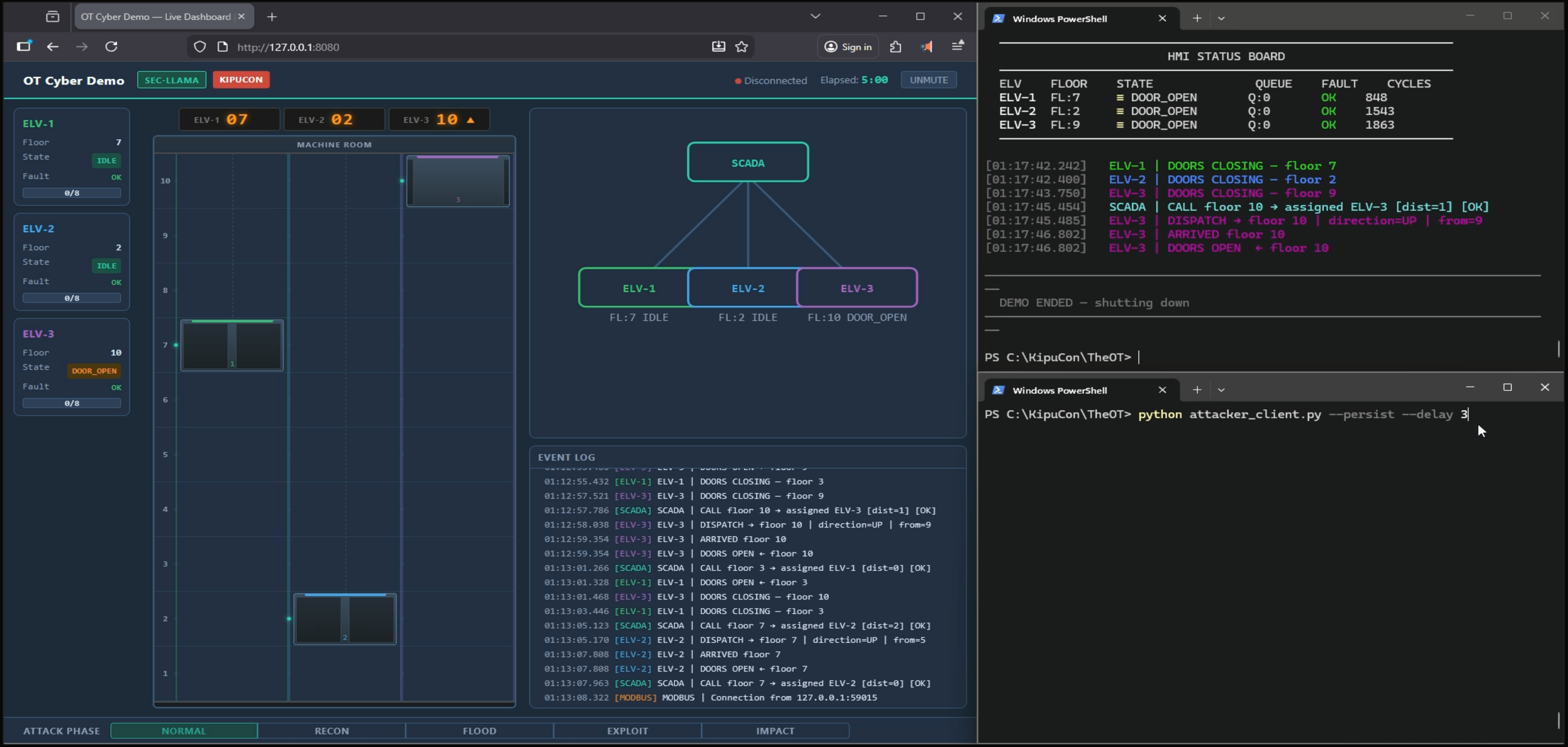
Command Queue Flooding & Service Disruption



ATTACK SCENARIO — ELV-1

PHASE 03

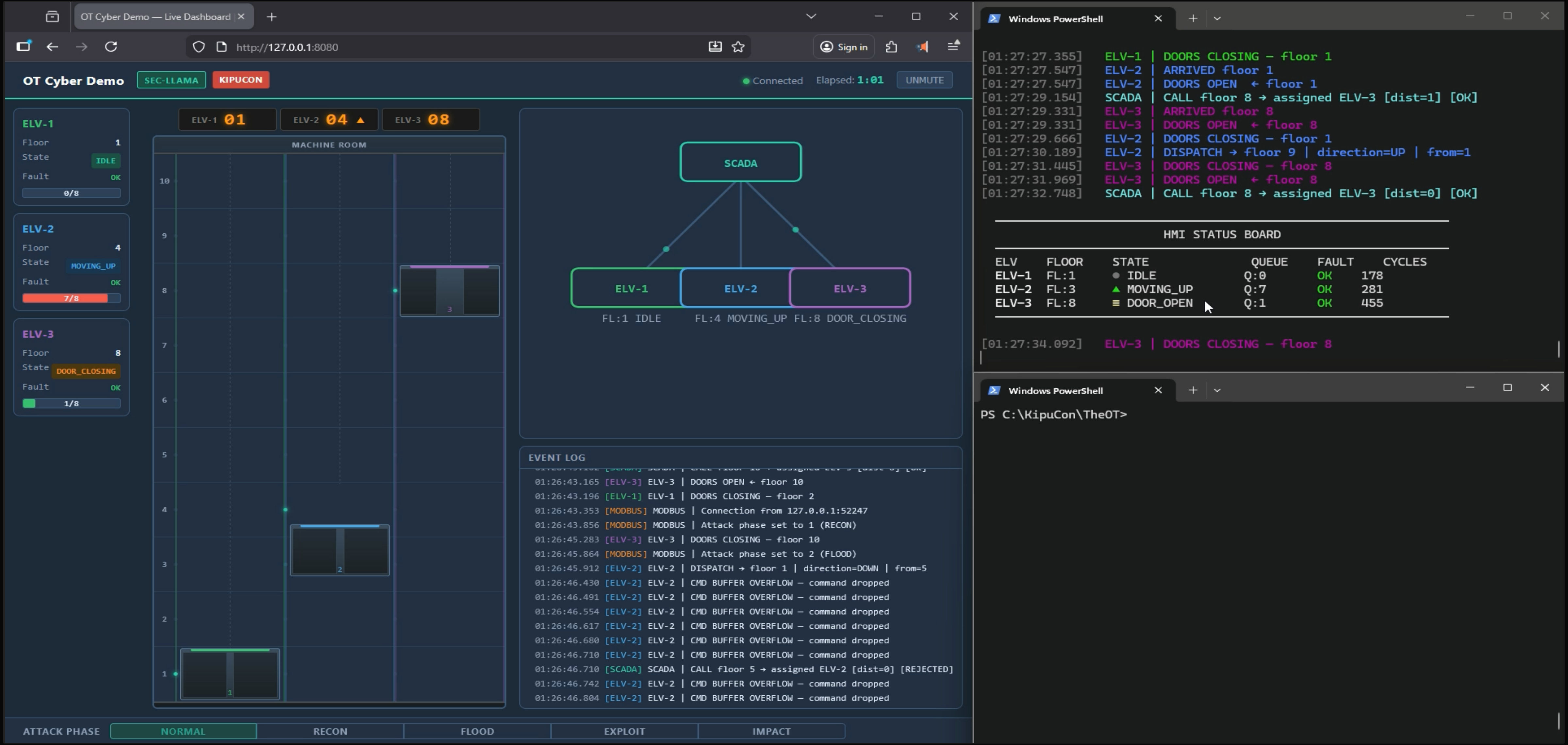
Elevator 1 — Doors Locked, Passengers Trapped



ATTACK SCENARIO — ELV-2

PHASE 03

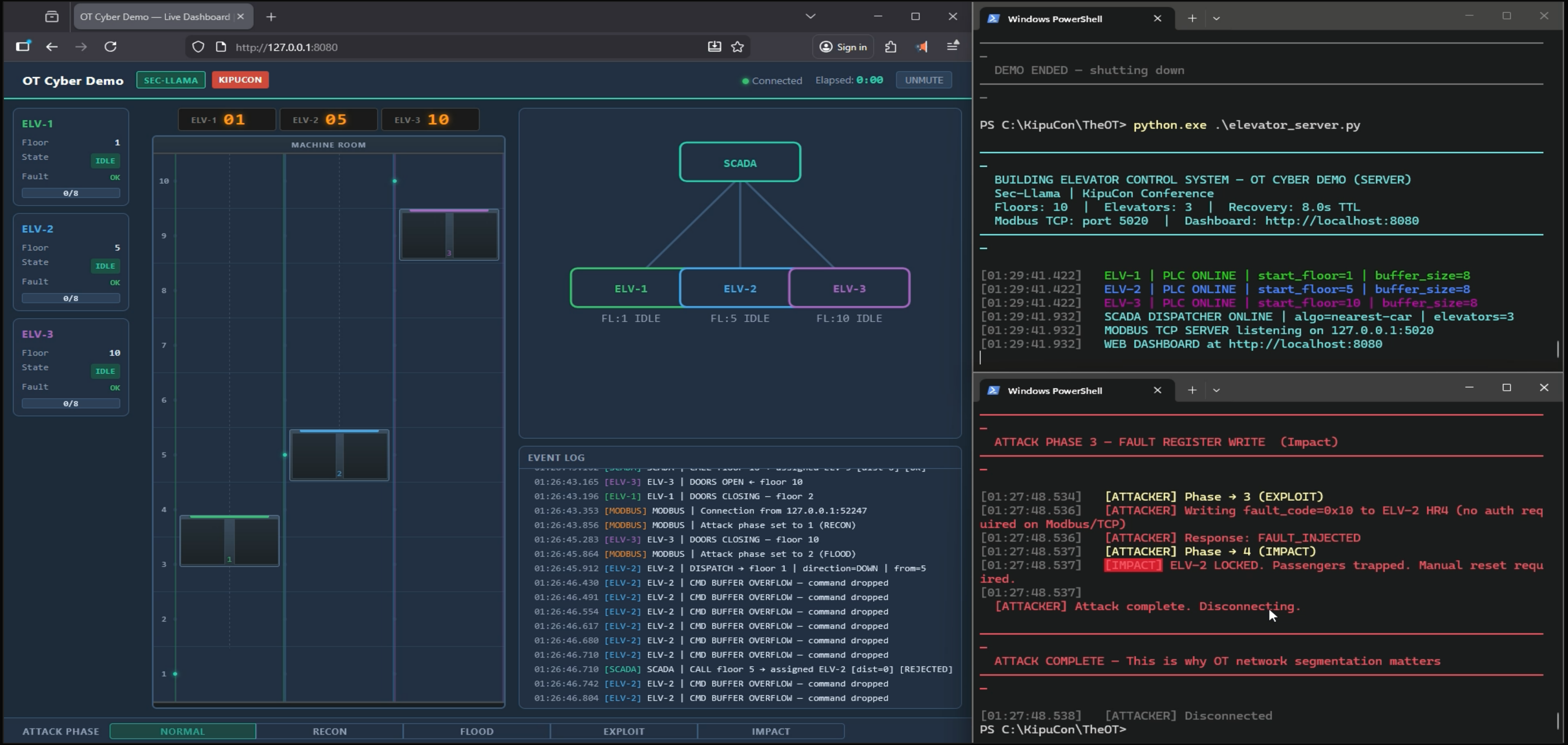
Elevator 2 — Cascading Failure, Second Trap



ATTACK SCENARIO — ALL TRAPPED

PHASE 04

Full Building Compromise — Every Elevator Locked Down



Four Phases. One Locked Elevator.

RECON

We looked around

Connected to the control network with no credentials. Read all PLC registers — floor, battery, queue depth. No alarm triggered.

FLOOD

We clogged the inbox

Sent 24 floor commands per second. Queue overflowed. Legitimate calls from the building system were rejected silently.

EXPLOIT

One command. Done.

Wrote fault_code=0x10 to register HR4. Controller locked instantly. Doors frozen. Passengers trapped. Total attack time: under 1 second.

PERSIST

We kept it locked

Re-wrote HR4 every 2 seconds. Elevator couldn't auto-recover. Without our intervention, it stays locked indefinitely.

No special hacking tools. No exploited vulnerabilities. Just: no password required.

That was a simulation.
But the technique is real.

These exact attack patterns have already been used to:

- 🔌 Cut power to 230,000 homes — for up to 6 hours
- 💥 Nearly trigger an explosion at a petrochemical plant
- ☢️ Set back a country's nuclear program by 2 years

DECEMBER 23, 2015 · UKRAINE · CONFIRMED STATE-SPONSORED ATTACK

Ukraine Power Grid — Lights Out.

- Phishing emails → malware installed → 6 months of silent reconnaissance
- Operators watched their own cursors move on screen, opening circuit breakers
- KillDisk malware wiped recovery systems — forcing manual restoration
- Phone line DDoS blocked customers from reporting the outage
- First confirmed cyber attack on a power grid in history

230,000

customers
lost power

1–6 hours

restored only by
manual breaker reset

> *The attackers used the SCADA system exactly as it was designed — they just weren't authorized. No protocol exploit. Just: network access + valid-looking commands.*

Triton — Designed to Kill.

- Target: Schneider Electric Triconex Safety Instrumented System (SIS)
- Goal: Disable the safety systems that prevent catastrophic failure
- Reverse-engineered a proprietary protocol + exploited a zero-day in the SIS
- SIS detected the attack and triggered an emergency shutdown — stopping the attack
- U.S. DOJ indicted a Russian government researcher in 2022

FIRST MALWARE

designed to target industrial safety systems

If the SIS hadn't caught it, the next step was an explosion in a facility handling flammable hydrocarbons.

> *The goal was not data theft. It was to create the conditions for a physical catastrophe. OT attacks can be designed to cause loss of life.*

Stuxnet — The First Cyber Weapon.

TARGET	Siemens S7-315/S7-417 PLCs controlling IR-1 uranium centrifuges
ATTACK	Spun rotors to 1,410 Hz then slowed to 2 Hz — causing physical failure
STEALTH	Recorded 21 seconds of normal data, replayed it on operator screens
ENTRY	USB drives carried into the air-gapped facility by infected contractors
ZERO-DAYS	Used 4 Windows zero-days simultaneously — unprecedented for any malware

~1,000

centrifuges destroyed
out of ~9,000 at Natanz

Set Iran's nuclear program back 1–2 years

> *Stuxnet sent valid control commands using native industrial protocols — the PLCs executed them because there was no concept of authorization. The same trust-model problem we just demonstrated.*

Every OT Attack Shares the Same DNA.

1 No Authentication

No passwords or logins required. Anyone who reaches the network can control any device. Commands are trusted blindly.

Modbus, BACnet, DNP3 — none require login by design.

2 Flat Network

IT and OT systems share the same network. Compromise a PC, get access to the PLCs. There's no wall between the office and the machines.

One phishing email is all it takes.

3 Legitimate Commands

Attackers use the protocol exactly as it was designed. There's nothing 'suspicious' to detect — it looks like normal operation.

No exploit needed. Just: network access.

4 Physical Damage

This isn't data theft. It's real-world destruction of equipment, infrastructure, and — ultimately — risk to human life.

You can't ctrl+Z a power grid failure.

This isn't just a Modbus problem — it's a trust model failure across most industrial protocols.

How to Stop This.

Configuration and network changes only.

01 Network Segmentation

EFFORT: MEDIUM

Put OT devices on their own locked room in the network (VLAN). Only the SCADA system can reach port 502.

Why it works: Even if an attacker gets into the office network, they can't reach the PLCs. This alone stops most OT attacks.

02 OT-Aware Firewall

EFFORT: MEDIUM

A firewall that understands the specific language machines speak (Modbus, BACnet). Blocks unauthorized write commands.

Why it works: Tools like Claroty and Dragos can block FC=6 write commands from unexpected sources.

03 Write-Protect Critical Registers

EFFORT: LOW

Lock the most dangerous registers (like HR4 — the fault code) so only the SCADA system can write to them.

Why it works: A checkbox — just not checked by default. Prevents the exact one-packet attack we just demonstrated.

04 Anomaly Detection

EFFORT: LOW

Monitor command frequency. Normal: 1–3 commands per minute. Our attack: 24 per second. A simple threshold rule catches it.

Why it works: Even without understanding OT protocols, pattern-based alerts would have flagged our flood phase immediately.

Five Things to Take Home.

1 **OT systems are everywhere and mostly undefended**

Elevators, power grids, water treatment, mining equipment — critical infrastructure that most people don't think of as 'hackable'.

2 **The protocols were designed for machines — not the internet age**

Modbus is 45 years old. It was designed for isolated factory floors. It was never meant to be network-connected.

3 **One packet can cause real physical damage**

We demonstrated it in under 60 seconds. A single write to a register. No special tools, no exploits.

4 **The defender's gap is closing — because of AI**

What Sammy Azdoufal did in a weekend with Claude Code used to require years of specialized expertise. The population of potential attackers just got much larger.

5 **Ask your vendors: what's your OT security posture?**

Any device connected to a building management system is a potential entry point. Security must be part of the conversation from day one.

Questions?

"Is this a real attack vector?"

Yes. ICS-CERT has published advisories on unauthenticated Modbus writes. The 2021 Oldsmar Water Treatment incident used the same pattern — an attacker connected remotely and changed chemical dosing levels.

"Do real elevators use Modbus?"

Elevator controls are often integrated into Building Management Systems via PLCs using Modbus or BACnet. Even when elevators don't speak Modbus directly, their BMS integration layer usually does — and that's the attack surface.

"What's the hardest part in practice?"

Getting network access to the OT segment. If properly segmented (a VLAN with a firewall), the attacker can't even reach port 502. Network segmentation alone stops most of these attacks.

"Can you cascade-attack a real building?"

If the PLCs are on the same network with no segmentation, yes — each PLC is independently addressable. Our demo showed all 3 elevators locked in under 10 seconds.

Thank You

Sec-Llama

Offensive Security Experts · Lima, Peru · LATAM

"Decrypting the Future. Honoring the Past."

KipuCon 2026 · Lima, Peru · May 13